ELMS-007 — Insecure Session Cookie & Session Fixation

Attribute	Detail
Finding ID	ELMS-007
Severity	Low
CVSS 4.0	3.1 — CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:A/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N
OWASP 2021	A07 — Identification & Authentication Failures (also A05)
CWE	CWE-384, CWE-1004, CWE-614, CWE-1275
Affected component	All authenticated pages; cookie set at session_start()
Parameter	PHPSESSID cookie
Auth context	None to observe; fixation targets a victim who later logs in
Status	Confirmed

Description & Root Cause

`PHPSESSID` is issued as `Set-Cookie: PHPSESSID=…; path=/` with **no `HttpOnly`** (script-readable), **no `Secure`** (would transmit over cleartext), and **no `SameSite`** (attached to cross-site requests -> enables CSRF, ELMS-005). The login handlers set `$_SESSION['emplogin']` / `['alogin']` without calling `session_regenerate_id(true)`, so a pre-login session id remains valid after authentication (session fixation).

Business Impact

Facilitates session hijacking (no HttpOnly), cleartext interception (no Secure), CSRF (no SameSite) and session fixation (no rotation). Individually Low, but each weakness widens the blast radius of another vector and can contribute to account takeover.

Proof of Concept — Step by Step

Step 1 — Inspect the cookie. Any ELMS response sets `PHPSESSID` without the three security attributes.

Step 2 — Observe no rotation. Note the pre-login `PHPSESSID`, authenticate, and observe the same id remains valid — the application never rotates it on privilege change.

```
[FIGURE 1 - SUGGESTED CAPTURE]
Tool   : curl -I http://localhost/elms/   (or browser > Application > Cookies)
Screen : the Set-Cookie: PHPSESSID=...; path=/ response header
Red box: the END of the Set-Cookie line - highlight the ABSENCE of
         HttpOnly, Secure and SameSite attributes
```

HTTP Evidence

`evidence/responses/01_root.resp`: `Set-Cookie: PHPSESSID=bf071gksvqokt2tvdhgjr6cijm; path=/`. Source review: no `session_regenerate_id` call anywhere in the login flow.

Remediation

Set hardened cookie params before `session_start()` and rotate the id on login:

```
session_set_cookie_params(['lifetime'=>0,'path'=>'/','httponly'=>true,'secure'=>true,'samesite'=>'Lax']);
session_start();
// after verifying credentials:
```

```
session_regenerate_id(true);
$_SESSION['emplogin'] = $email;
```

Add idle and absolute session timeouts and destroy the session fully on logout.

Re-test Procedure

Inspect `Set-Cookie` for `HttpOnly`, `Secure`, `SameSite`; confirm the session id value changes immediately after login.

Exploitation Feasibility

Low–moderate; depends on a companion vector or fixation setup.

Existing CVE Verification

No product CVE (configuration/design). Status: **No matching CVE identified**.

References

- OWASP WSTG-SESS-02/-03; Session Management Cheat Sheet; CWE-384/1004/614/1275.

Conclusion

Confirmed insecure session cookie and missing session-ID rotation. Low severity standalone; hardens several other issues (notably CSRF) once fixed.